

PHP, formulaires et base de données

Suivre une valeur depuis le formulaire jusqu'à son enregistrement, puis son affichage.

Navigateur —POST? PHP : vérifier ? PDO/MySQL : enregistrer ? redirection GET ? relire ? afficher

POST et GET

POST transporte les données d'une action de formulaire, par exemple créer ou renommer un projet. GET demande une page ou une ressource ; ses paramètres peuvent apparaître dans l'URL, comme l'identifiant du projet à ouvrir ou des options d'aperçu.

Une redirection après un ajout réussi renvoie vers une adresse GET. Actualiser cette page ne renvoie donc pas le même formulaire POST et évite normalement une création répétée.

Session et jeton CSRF

La session permet au serveur de reconnaître une continuité entre les requêtes du même navigateur. Le jeton CSRF est créé côté serveur, placé dans le formulaire et comparé au retour avant une écriture. S'il manque ou ne correspond pas, PHP refuse la demande.

Le jeton ne valide pas le nom : il vérifie que la demande contient le jeton attendu. Le nom doit être validé séparément.

Valider côté serveur

Le navigateur peut aider à la saisie, mais les valeurs reçues restent contrôlables par une personne. PHP doit donc vérifier le type, retirer les espaces inutiles, refuser le texte vide et appliquer la longueur maximale choisie. En mission 4, le nom est limité à 150 caractères.

PDO et requête préparée

PDO ouvre la connexion MySQL. Le DSN précise hôte, port, base et charset=utf8mb4. Une requête préparée garde séparés le texte SQL et les valeurs fournies par l'utilisatrice :

```
prepare('INSERT INTO projects (name) VALUES (:name)')
execute(['name' => $nom])
```

Le marqueur :name est une place réservée. On ne colle pas le nom saisi dans la chaîne SQL. Pour modifier un projet, la condition WHERE id = :id est essentielle : elle limite la modification au projet visé.

Échapper au moment de l'affichage

La validation et l'échappement répondent à deux questions différentes. La validation décide si la donnée convient. htmlspecialchars(\$texte, ENT_QUOTES, 'UTF-8') transforme les caractères spéciaux quand le texte est inséré dans du HTML ou un attribut entre guillemets.

Un nom comme Projet doit rester du texte, pas devenir une balise.

| Étape | | À vérifier |

| Réception | | La méthode attendue et les champs sont présents. |

| Protection | | Jeton CSRF correct avant toute écriture. |

| Validation | | Type, contenu, limites. |

| Écriture | | PDO + requête préparée. |

| Réponse | | Redirection ou message honnête ; texte échappé à l'affichage. |

Phrase pour l'expliquer

« PHP reçoit la demande et ne fait pas confiance aux champs. Il vérifie le jeton et les valeurs. PDO exécute une requête préparée. Quand je réaffiche le nom, je l'échappe pour qu'il reste du texte HTML. »

À relier aux missions 4 et 5. Les accès réels de la base ne doivent jamais être recopiés dans une fiche ou un dépôt.